

Este é nosso CTF de Hardware Hacking, usando a firmware vulnerável IoTGoat. Vamos testar o seu conhecimento em Hardware Hacking descobrindo alguns artefatos nesta imagem.

Quais são os dois aplicativos fornecidos pelo IoTGoat na interface web?

Pegamos o IP local do BR-LAN.

E podemos abrir no navegador:

```
br-lan    Link encap:Ethernet  HWaddr 08:00:27:BB:27:68
          inet addr:192.168.1.14  Bcast:192.168.1.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:febb:2768/64  Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:322 errors:0 dropped:2 overruns:0 frame:0
          TX packets:1653 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:40647 (39.6 KiB)  TX bytes:817299 (798.1 KiB)

eth0      Link encap:Ethernet  HWaddr 08:00:27:BB:27:68
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:330 errors:0 dropped:0 overruns:0 frame:0
          TX packets:1699 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:45587 (44.5 KiB)  TX bytes:859173 (839.0 KiB)

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128  Scope:Host
          UP LOOPBACK RUNNING  MTU:65536  Metric:1
          RX packets:20 errors:0 dropped:0 overruns:0 frame:0
          TX packets:20 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:1893 (1.8 KiB)  TX bytes:1893 (1.8 KiB)

standard input
```

OWASP IoTGoat

Não seguro https://192.168.1.14/cgi-bin/luci

#1 Crowdsourced C... | HackerOne | #1 Trus...



Authorization Required

Please enter your username and password.

Username

Password

Login

Reset

OWASP IoTGoat

```

a de linha
<!DOCTYPE html>
<html lang="en">
  <head>
    <meta charset="utf-8">
    <title>OWASP IoTGoat</title>
    <meta name="viewport" content="initial-scale=1.0">
    <link rel="stylesheet" href="/luci-static/bootstrap/cascade.css">
    <link rel="stylesheet" media="only screen and (max-device-width: 854px)" href="/luci-static/bootstrap/mobile.css" type="text/css" />
    <link rel="shortcut icon" href="/luci-static/bootstrap/favicon.ico">
    <script src="/luci-static/resources/cbi.js"></script>
    <script src="/luci-static/resources/xhr.js"></script>
  </head>

  <body class="lang_en">
    <header>
      <div class="fill">
        <div class="container">
          <a class="brand" href=""></a>

          <div class="pull-right">
            <span id="xhr_poll_status" style="display:none" onclick="XHR.running() ? XHR.halt() : XHR.run()">
              <span class="label success" id="xhr_poll_status_on">Auto Refresh on</span>
              <span class="label" id="xhr_poll_status_off" style="display:none">Auto Refresh off</span>
            </span>
          </div>
        </div>
      </div>
    </header>

    <div id="maincontent" class="container"><noscript>
      <div class="alert-message warning">
        <h4>JavaScript required!</h4>
        <p>You must enable JavaScript in your browser or LuCI will not work properly.</p>
      </div>
    </noscript>

    <form method="post" action="/cgi-bin/luci">
      <div class="alert-message warning">
        <p>Invalid username and/or password! Please try again.</p>
      </div>
      <div class="cbi-map">
        <h2 name="content">Authorization Required</h2>
        <div class="cbi-map-descr">
          Please enter your username and password.
        </div>
        <div class="cbi-section"><div class="cbi-section-node">
          <div class="cbi-value">
            <label class="cbi-value-title">Username</label>
            <div class="cbi-value-field">
              <input class="cbi-input-text" type="text" name="luci_username" value="root" />
            </div>
          </div>
          <div class="cbi-value cbi-value-last">
            <label class="cbi-value-title">Password</label>
            <div class="cbi-value-field">

```

Seguindo o diretório apresentado na URL, não localizamos nenhuma senha.

```

root@IoTGoat:/# cat /www/cgi-bin/luci
#!/usr/bin/lua
require "luci.cacheloader"
require "luci.sgi.cgi"
luci.dispatcher.indexcache = "/tmp/luci-indexcache"
luci.sgi.cgi.run()root@IoTGoat:/#

```

Dentro da pasta /usr/lib/lua/luci/controller/iotgoat

Localizado um arquivo que informa as aplicações rodando:

```

root@IoTGoat:/tmp# cat /usr/lib/lua/luci/controller/iotgoat/iotgoat.lua
module("luci.controller.iotgoat.iotgoat", package.seeall)
local http = require("luci.http")
function index()
    entry({"admin", "iotgoat"}, firstchild(), "IoTGoat", 60).dependent=false
    entry({"admin", "iotgoat", "cmdinject"}, template("iotgoat/cmd"), "", 1)
    entry({"admin", "iotgoat", "cam"}, template("iotgoat/camera"), "Camera", 2)
    entry({"admin", "iotgoat", "door"}, template("iotgoat/door"), "Doorlock", 3)
    entry({"admin", "iotgoat", "webcmd"}, call("webcmd"))
end

function webcmd()
    local cmd = http.formvalue("cmd")
    if cmd then
        local fp = io.popen(tostring(cmd).. " 2>&1")
        local result = fp:read("*a")
        fp:close()
        result = result:gsub("<", "&lt;")
        http.write(tostring(result))
    else
        http.write_json(http.formvalue())
    end
end
root@IoTGoat:/tmp# _

```

Vemos que está rodando um serviço de camera e o doorlock.

R: FIAP{Camera,Doorlock}